

Sri Lanka Institute of Information Technology



Information Security Risk Management (IE3052)

Type 2 – MSME Cybersecurity Risk Assessment

CS.Y3.S1.WE

Group Members

Name	IT Number
LAKSHAN W M H C	IT23659230
LANDAGE P. D	IT23580626
KALHARA R W V K S	IT23555730
DALUWATTA L G	IT23578296

Table of Contents

1. Executive Summary.....	3
2. Risk Assessment and Analysis	3
2.1 Introduction to the MSME	3
2.2 Assessment Approach.....	4
2.3 Identified Assets and Risk Profiling	4
2.4 Existing Security Practices	4
2.5 Threats, Vulnerabilities, and Security Gaps.....	5
2.6 Risk Evaluation	5
2.7 Proposed Cybersecurity Controls and Justifications.....	5
2.8 Comparison with Alternative Approaches.....	6
3. Implementation and Training Plan	6
3.1 Roadmap for Implementing Recommendations.....	6
3.2 Cybersecurity Awareness Training Conducted.....	7
3.3 Feedback from the MSME Representative.....	7
4. Conclusion and Future Considerations	7
5. References.....	8
6. Appendix	8
Appendix A – Questionnaire and Engagement Evidence	8
.....	9
Appendix B – Awareness Training Evidence.....	9
Appendix C – MSME Feedback Evidence.....	11
.....	11

1. Executive Summary

The current document outlines the cybersecurity risk assessment undertaken by Wijesiri Consultants, which is a small consulting company involved in offering consultancy services for investment projects. This risk assessment was undertaken to determine the existing state of cybersecurity at the firm, to establish the most significant cyber threats that could affect the firm in relation to its operations, and to provide suitable recommendations that can be implemented within the capacity of a small firm. Based on the findings of the survey, the session on cybersecurity awareness, and the information provided by the MSME representative, it is clear that the firm operates in a dynamic manner and not necessarily using a permanent office location.

Some of the critical assets identified during the assessment include cloud-hosted workspace and storage, customer project documentation, personal computers and laptops, personal devices for communication, and email or online communications. Some of the critical threats identified include unauthorized access to cloud-hosted data, phishing and social engineering attacks, exposure of information from personal devices, lack of controls over remote work practices, and interruptions due to insufficient internal operational capability. While the company does update software and systems regularly, there was no indication that cybersecurity training had ever been done before the assessment. Other controls that were lacking or poorly defined included backup procedures, secure computing guidelines, and an incident response plan.

In order to mitigate these problems, the following are some of the inexpensive but helpful recommendations that can be considered: multi-factor authentication, better cloud access management, implementing basic device security policies, initiating a backup strategy, awareness training, and creating an easy-to-follow incident response plan. An awareness training session was also held within the scope of this engagement, and a positive feedback was received by the MSME representative regarding the usefulness of the training session. The questionnaire results, online training session, and feedback message are presented in the Appendix section.

2. Risk Assessment and Analysis

2.1 Introduction to the MSME

The organisation under analysis is called Wijesiri Consultants and represents a small consultancy business in terms of investment projects. According to the data collected using the questionnaire, the company operates for five years and provides services to about 30 people or groups per year. At present, Wijesiri Consultants operates with one employee and five volunteers, and the company's chief executive officer is Mr. S. Wijesiri. The company does not have an office building and utilises a specific approach based on digital technology and remote work. Details concerning the findings from the questionnaire can be found in Appendix A.

A similar business model is viable for consultation firms since most processes can be performed remotely. Nevertheless, there is a different set of cyber risks. For example, the business does not face challenges in terms of the infrastructure. The major concerns include cloud access, safety of files and accounts, personal devices, etc.

2.2 Assessment Approach

The assessment has been done in accordance with the guidelines provided for this task, which involve asset identification, asset criticality evaluation, threat/vulnerability analysis, control analysis, and prioritization based on the impact and likelihood of risks. The risk assessment process has been conducted following the best practices as per the guidelines provided in ISO/IEC 27005 and NIST SP 800-30, including organizational context, asset, threat, vulnerability, control, and risk treatment options.

However, considering the data obtained from the questionnaire answers, online awareness session, and direct communications with the MSME representative, the report should be seen more as a qualitative cybersecurity risk assessment rather than a technical penetration testing or forensic investigation. Nonetheless, the available data has been sufficient enough to identify the top risk areas and provide appropriate recommendations that the organization can implement.

2.3 Identified Assets and Risk Profiling

Asset	Risk profile / importance
Cloud-Based Workspace and Storage	Used to store consultancy files, project records, and shared business documents. This is a core operational asset because the organisation depends on cloud access for daily work.
Client Project Data and Consultancy Records	Includes project-related documents, consultancy materials, and other service records. Loss or exposure of this information would directly affect trust and service delivery.
Personally Owned Desktop and Laptop Devices	Used to access files, cloud accounts, and communication channels. These devices are important for productivity but increase risk because they may not follow a formal security baseline.
Mobile Devices Used for Business Activities	Used for calls, messaging, and email access. These devices support flexibility, but can expose business accounts if lost, stolen, or used insecurely.
Email and Online Communication Channels	Support communication with clients and collaborators. If compromised, they can be used for phishing, impersonation, or unauthorised access attempts.

2.4 Existing Security Practices

From the questionnaires, it is evident that the organisation has always maintained its systems and software through timely patching. This is an excellent existing control as it minimises vulnerabilities and indicates that the organisation understands basic cybersecurity. Cloud-based storage is another good practice that enhances the availability of information systems. Moreover, the representative was willing to listen to the advice of the students during the engagement. However, there was no information concerning any other important security mechanisms, including multi-factor authentication for critical accounts, backup and restoration processes, endpoint security software, tips on how to create passwords securely and use devices safely, or incident response procedures. Before the audit commenced, the company had never given any form of cybersecurity training to its employees. This point is elaborated further in Appendix A below.

2.5 Threats, Vulnerabilities, and Security Gaps

- **Unauthorised access to cloud-based data:** Because the organisation depends on cloud storage and shared files, weak account protection or broad sharing permissions can expose consultancy information, project records, or other business documents.
- **Phishing and social engineering:** Lack of earlier awareness training increased the chance that users could be misled by fake emails, suspicious links, malicious attachments, or fake login pages.
- **Exposure through personally owned devices:** Personal devices used for work may not always have strong passwords, malware protection, or good separation between personal and business use. This raises the risk of information exposure if a device is lost, stolen, or compromised.
- **Weak control over remote working practices:** Distributed working can lead to inconsistent security habits, insecure networks, and accidental exposure of information.
- **Limited internal operational capacity:** With a small team, routine security checks, access reviews, and incident response may be delayed, which can increase business disruption even during a small cyber issue.

2.6 Risk Evaluation

The identified risks were prioritised using impact and likelihood, as required by the assignment brief. The table below summarises the risk evaluation outcome.

Risk	Likelihood	Impact	Risk Level
Unauthorised access to cloud-stored data	High	High	High
Phishing and social engineering	High	High	High
Data exposure through personally owned devices	Medium to High	High	High
Weak control over remote working practices	Medium	Medium to High	Medium to High
Limited internal operational capacity	Medium	Medium	Medium

2.7 Proposed Cybersecurity Controls and Justifications

- **Enable multi-factor authentication:** MFA should be enabled on cloud, email, and other important business accounts because it is one of the most practical and cost-effective ways to prevent unauthorised access.
- **Improve cloud access control:** File-sharing permissions should be reviewed regularly and limited to the people who genuinely need access. This reduces unnecessary exposure of consultancy information.
- **Apply basic device security requirements:** All devices used for work should have password or PIN protection, screen lock, updated software, and basic malware protection where possible.
- **Maintain regular backups:** Important consultancy records should be backed up regularly. A simple backup routine can reduce the damage caused by accidental deletion or account compromise.

- **Continue awareness support:** Regular awareness sessions should be continued because the initial evidence showed a clear training gap, and the session feedback confirmed that the programme was useful.
- **Prepare a basic incident response checklist:** The organisation should have a short, clear procedure for what to do if there is a suspicious login, phishing email, lost device, or compromised account.

2.8 Comparison with Alternative Approaches

Recommended Control	Alternative	Why the Recommended Control Was Chosen
MFA on cloud/email accounts	Password-only protection	MFA gives stronger protection at low cost
Regular cloud + separate backups	Cloud storage only	Separate backups improve recovery if files are deleted or accounts are compromised
Awareness training	No formal user training	Training reduces phishing and unsafe behavior risks
Basic device security rules	Uncontrolled personal device use	Simple rules improve security without high cost

The selected controls were chosen because they are practical, affordable, and suitable for the working model of Wijesiri Consultants. Since the organization operates as a small consultancy business with limited resources, the recommended measures provide meaningful risk reduction without requiring expensive infrastructure or complex technical deployment.

3. Implementation and Training Plan

3.1 Roadmap for Implementing Recommendations

Phase 1 – Immediate actions

- Enable MFA on email and cloud accounts
- Review and strengthen important passwords
- Ensure all work-used devices have screen lock and password protection
- Identify the most critical files and accounts

Phase 2 – Short-term actions

- Review and reduce unnecessary cloud sharing permissions
- Establish a simple backup process for important records
- Introduce basic guidance for secure use of personal devices in work
- Assign one person to carry out basic cybersecurity checks

Phase 3 – Medium-term actions

- Continue periodic cybersecurity awareness support
- Prepare a simple incident response checklist
- Review the effectiveness of newly applied controls
- Improve practices further based on feedback and future needs

3.2 Cybersecurity Awareness Training Conducted

In terms of engaging with Wijesiri Consultants, an introductory session aimed at improving the organisation's knowledge about potential cybersecurity threats and measures that could be taken to protect against these threats was held. The session was conducted virtually and covered various aspects of cybersecurity that were relevant to the organisation, namely phishing, passwords, multi-factor authentication, safe cloud sharing, proper handling of personal devices, and what actions should be taken in case any suspicious activity is noted. The information regarding the session is included in Appendix B.

It is important to point out that the session had been designed in such a way that it would not be too technical because the need for a session on the subject matter had been highlighted through the questionnaire. Thus, the main objective of the session was to identify the most common risks faced by small business owners and how to minimise those risks through good security practices.

3.3 Feedback from the MSME Representative

Feedback was provided by the MSME representative following the awareness event. According to the representative's email feedback, the program was helpful and especially useful for increasing awareness about cyber security, especially using public Wi-Fi safely. The representative also praised the effort made in organizing the event and suggested that in subsequent events, more information could be provided about cloud computing. The feedback provided is attached as Appendix C.

The feedback provided above is crucial since it indicates that the engagement activity was relevant both from an academic perspective and also useful to the selected MSME. This feedback will also meet the assessment criteria since it requires that MSME feedback be considered in evaluating the whole assignment.

4. Conclusion and Future Considerations

The assessment suggests that Wijesiri Consultants has created a flexible digitalized environment by implementing cloud storage, personal device usage, remote communications, and decentralized working processes. Such an environment makes things easier, but also increases cybersecurity risks that should be managed. The most concerning risks included unauthorized cloud access, phishing and social engineering attacks, exposure of information through the use of personal devices, the inability to manage remote work processes, and disruptions due to insufficient internal capabilities.

Even though this company is doing quite well regarding regular updates to software and systems, the other important areas need to be worked on. These include awareness, backup processes, account security, and incident response planning. The suggested controls are applicable to any small business and do not require expensive infrastructure. They include multi-factor authentication, protecting devices, managing file sharing, conducting backup procedures, providing awareness training, and incident response planning.

As the business expands and develops new products and services, it should always review the security policies, access to sensitive information, keep up with updating the software and systems, improve backup practices, conduct awareness training sessions periodically, and re-assess cybersecurity risks.

5. References

- [1] ISO/IEC, Information security, cybersecurity and privacy protection — Guidance on managing information security risks, ISO/IEC 27005.
- [2] Joint Task Force Transformation Initiative, Guide for Conducting Risk Assessments, NIST Special Publication 800-30 Rev. 1, Sep. 2012.
- [3] G. Stoneburner, A. Goguen, and A. Feringa, Risk Management Guide for Information Technology Systems, NIST Special Publication 800-30.

6. Appendix

The following supporting material is provided separately from the main report body in accordance with the assignment brief. The appendix includes questionnaire evidence, awareness training evidence, and MSME feedback evidence.

Appendix A – Questionnaire and Engagement Evidence

1 response

Email: swijecey@gmail.com

GENERAL INFORMATION

Organization Name: Wijesiri Consultants

Company Registration Number: No responses yet for this question.

Company Address: 74/2,Brahmanagama,Pannipitiya

Primary Contact Name: S.Wijesiri

Designation (Primary Title): CEO

Primary Contact Phone Number: S.Wijesiri

Primary Contact Email: swijecey@gmail.com

Figure 1

No responses yet for this question.

Social Media Handles (If Any): No responses yet for this question.

ORGANIZATION DETAILS

Mission Statement: No responses yet for this question.

Brief Description of Your Organization: Project Consultants

What type of organization do you represent?

Type: 100% Non-Profit

What type of organization do you represent?

Industry: Nonprofit organization (100%)

Number of Employees: 1

Figure 2

Number of Volunteers: 5

Number of Individuals / Groups Served Annually: 30

Years in Operation: 5

CURRENT NEEDS AND GOALS

Why did your organization seek assistance from the Sri Lanka Institute of Information Technology? (Select all that apply)

To assess and strengthen the overall cybersecurity posture of our organization (100%)

To enhance security awareness among employees and stakeholders (0%)

To conduct penetration testing and vulnerability assessments (0%)

To implement security policies and procedures (0%)

To conduct security audits (0%)

To conduct security training (0%)

To conduct security assessments (0%)

To conduct security audits (0%)

To conduct security training (0%)

To conduct security assessments (0%)

If you selected multiple answers above, please state one (1) that is the highest priority

To assess and strengthen the overall cybersecurity posture of our organization

What specific goals or outcomes would you like to achieve through collaboration with our students?

Improve the services

Do you have a specific timeline for completing these projects or achieving these goals?

no

Figure 3

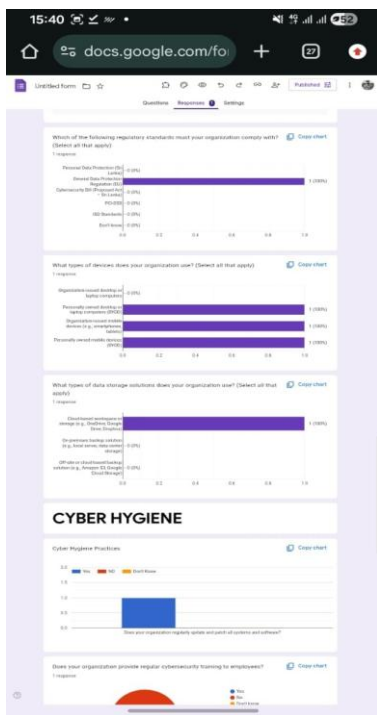


Figure 4

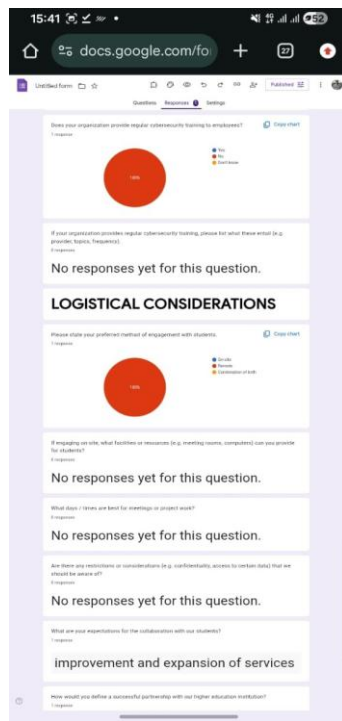


Figure 5

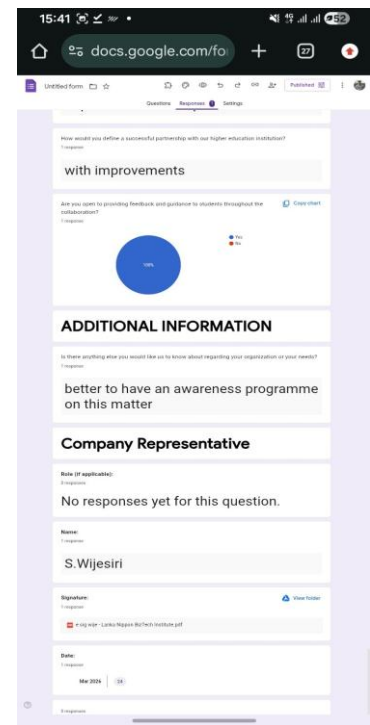


Figure 6

Appendix B – Awareness Training Evidence

Cybersecurity Awareness Training

For Wijesiri Consultants

Simple practices to protect files, accounts, devices, and business communication.

Business Files

WIJESIRI CONSULTANTS

Consultancy in Investment Projects

Cloud files
Protect access to shared docs

Business accounts
Use strong passwords + MFA

Personal devices
Keep phones and laptops secure

Stay Secure. Stay Safe.

Figure B.1 Awareness session opening

The image shows a Zoom meeting window with a presentation slide titled "3 Common Cyber Threats". The slide content is as follows:

Threat	Description
Phishing emails and fake messages	Attackers send messages that try to steal login details or install malware.
Weak or reused passwords	Using the same password in many places makes account takeover easier.
Suspicious links and attachments	Unknown files or links can lead to fake login pages or malicious downloads.
Unauthorized access to cloud files	Shared folders may be seen by unintended people if permissions are not controlled.
Lost or stolen mobile or laptop devices	A missing device can expose business accounts and stored information.

Key idea: Most attacks against small businesses begin with a simple mistake or weak account protection.

At the top of the slide, there are two video thumbnails: one for "Kaveen Kalhara" and another for "S.Wijesiri". The Zoom interface shows the meeting name "POORNIMA" and a "Sign in" button in the top right corner.

Figure B.2 Common cyber threats slide

The image shows a Zoom meeting window with a presentation slide titled "4 How to Protect Accounts". The slide content is as follows:

Best practices for accounts

- Use strong passwords with a mix of letters, numbers, and symbols.
- Do not reuse the same password for many accounts.
- Enable Multi-Factor Authentication (MFA) wherever possible.
- Do not share passwords with others or store them unsafely.
- Log out from accounts when using shared or public devices.

Tip: Change weak or old passwords regularly and avoid using personal passwords for business accounts.

Why MFA matters

Business Account

123456

Even if a password is stolen, MFA adds an extra verification step and helps stop unauthorized access.

Use MFA on email, cloud storage, and any account that supports it.

The slide also features two video thumbnails at the top: "Kaveen Kalhara" and "S.Wijesiri". The Zoom interface includes the meeting name "POORNIMA" and a "Sign in" button in the top right corner.

Figure B.3 Account protection and MFA slide

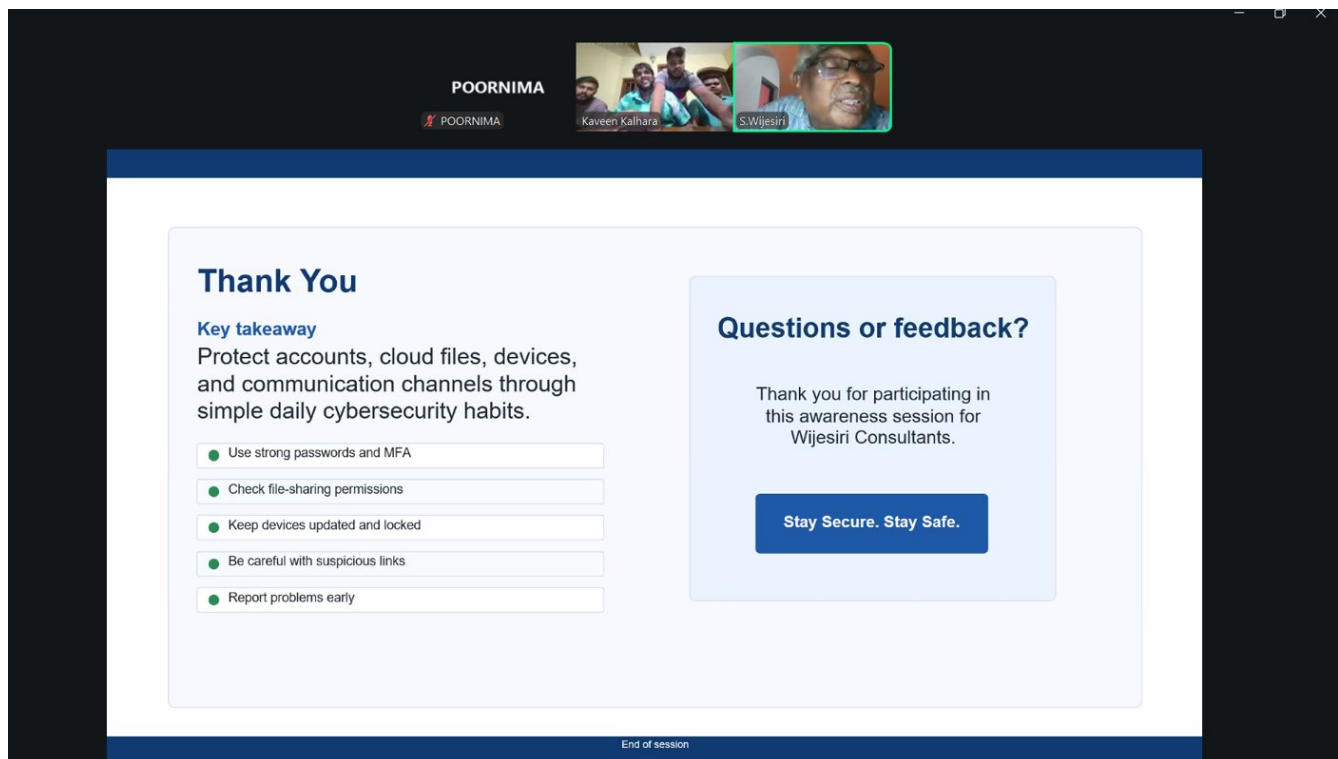


Figure B.4 Awareness session closing

Appendix C – MSME Feedback Evidence



Figure C.1 Feedback email from MSME representative